

Cyber Range Scenario Design Document

R5 — Phishing-to-Encrypt Ransomware Campaign

Document type: Attack Simulation Storyboard / Scenario Design Specification **Audience:** Simulation platform engineering team (frontend, backend, telemetry, scoring) **Classification:** Training / Cyber Range — **Simulated behavior only. No live malware, exploits, or weaponized payloads are described or required.** **Version:** 1.0 **Scenario ID:** R5-PHISH2ENC **Difficulty:** Intermediate → Advanced **Estimated playthrough:** 35–55 minutes (real time), ~6 hours simulated time

3. Red Team Journey

The Red Team role is the **objective-driven attacker view**. In scripted mode the engine plays these beats automatically; in interactive mode the Red player chooses the next action from a constrained menu at each stage.

Beat	What the Red player sees / does	Objective progress
Recon & weaponize	Pick target persona (Finance), select lure theme (invoice), arm document	Access objective unlocked
Deliver phish	Send email; watch delivery / open / enable signals	Awaiting victim action
Get execution	Macro fires; PowerShell cradle reported as "live"	Foothold gained
Establish persistence	Confirm scheduled task + injected beacon survive reboot	Resilience gained
Command & control	Beacon checks in; interactive session available	Hands-on-keyboard
Discover	Run file/share/host discovery; map reachable assets	Target list built
Move laterally	Use harvested creds over RDP to FS01, BKP01, DC01	High-value footholds
Impact	Stage encryptor → detonate → inhibit recovery	Mission complete

Red dashboard elements to implement: objective tracker (per MITRE tactic), "stealth/heat" meter (rises as defenders generate alerts that go un-actioned vs. drops if the operator pauses), reachable-asset graph, and a "time-to-detection" countdown that the operator is implicitly racing.

Heat mechanic: every action has a *noise* value. Noise raises a hidden detection probability. If the SOC actions an alert tied to that noise, the operator's current action can be blocked/rolled back. This is what makes early detection matter mechanically.

4. Victim Journey

The Victim role is the **human experience**, rendered as a simulated desktop. No technical jargon — the learning point is recognizing social-engineering cues and the consequences of clicking.

1. **Inbox.** A new email arrives: vendor branding, urgent subject, an attachment. Subtle red flags exist (lookalike sender domain, slight tone mismatch, external-sender banner).
2. **Decision point.** The victim can **Report Phish**, **Delete**, **Open attachment**, or **Ignore**. Reporting here is the cleanest possible win.
3. **The document.** Opening shows a blurred "protected" document with an **Enable Content** banner. Another decision point.
4. **Enable content.** Choosing this triggers the chain. The desktop appears normal; a brief "loading" hint is the only cue.
5. **Degradation.** Over simulated time the machine feels slightly slower; occasional disk activity. Most victims notice nothing.
6. **Impact moment.** If the campaign reaches encryption, files on the desktop visibly change to `.locked`, wallpaper switches to a ransom message, and a `README_RESTORE.txt` note opens automatically.
7. **Aftermath.** The victim is locked out of work; a simulated IT/SOC contact channel appears ("Report incident").

Scoring hook for the victim role: points for reporting at step 2, partial credit for refusing **Enable Content** at step 4, points for promptly reporting the impact at step 6.

5. SOC Analyst Journey

The SOC role works a **simulated SIEM + EDR console** fed by the telemetry bus. The journey is triage → investigate → pivot → escalate.

1. **Alert queue populates** as the campaign advances. Early, low-confidence signals (email-gateway flag, suspicious PowerShell) appear first; high-confidence signals (mass file modification) appear late.
2. **Triage** — analyst ranks/dispositions alerts (True Positive / False Positive / Benign / Escalate). Mis-triage of an early TP is the most punishing scoring event.
3. **Investigate** — open an alert to see the underlying events: process tree, parent/child, command line (display-only), network destinations, user, host.
4. **Pivot** — search the SIEM by host, user, hash, or destination to find related activity and scope the incident.
5. **Build the story** — assemble a timeline; identify patient zero, persistence, C2, and lateral movement.
6. **Escalate** — hand off to Blue Team with a scoped incident package (affected hosts, IOCs, recommended containment).

SOC dashboard elements: alert queue with severity/confidence, raw event search, process-tree visualizer, host/user pivot, and an "incident package" builder that feeds the Blue Team.

Visibility model: the SOC sees only what telemetry exists for. Coverage gaps (e.g., script block logging disabled on the victim host) are a deliberate teachable variable the scenario author can toggle.

6. Blue Team Journey

The Blue Team role holds the **response levers** and operates against the clock. Actions cost simulated time and may have side effects.

Action	Effect in simulation	Cost / risk
Isolate host (network quarantine)	Cuts that host's links in the entity graph; stops further spread <i>from</i> it	Disrupts user; if wrong host, wasted time
Kill / block process	Removes injected beacon state on a host	Operator may re-establish if persistence intact
Disable account	Stops lateral movement using that credential	May lock out a real user (false-positive cost)
Block C2 destination	Severs beacon link at the egress; operator loses hands-on-keyboard	Operator may rotate to backup channel
Force password reset (scoped)	Invalidates harvested credentials	Org-wide friction if over-broad
Restore from backup	Available only if backups not yet inhibited	Time-consuming; useless after T1490 fires
Activate IR / declare incident	Unlocks coordinated containment; notifies leadership	Triggers business-impact accounting

Blue dashboard elements: asset map with state coloring, containment action panel (with confirm + blast-radius preview), recovery readiness indicator (are backups still good?), and a live business-impact meter.

The core Blue tension: **act fast on incomplete information (risk false positives) vs. wait for certainty (risk encryption)**. The scoring rewards correct, *timely*, *proportionate* action.

7. Stage-by-Stage Attack Flow

Each stage below is a node in the state machine. The format gives developers everything needed to implement the node: what it changes, what it emits, what defenders can see, and how it's drawn.

Telemetry note: Event schemas are illustrative JSON. Field names mirror common log sources (Sysmon, Windows Security, PowerShell operational, email gateway, EDR, network) so the SIEM view feels authentic. All values are synthetic.

Stage 1 — Spear Phishing (T1566.001 / T1566.002)

- **Goal:** Deliver a weaponized lure to a high-value user.
- **Attacker Action (simulated):** A phishing email is injected into victim `j.harper@northwind.local` from lookalike domain `northwind-billing[.]com`, subject "Overdue Invoice #INV-44821," with a macro-enabled attachment

Invoice_44821.xlsm. Implemented as: create EmailMessage entity, deliver to inbox, emit gateway event.

- **Victim Impact:** New email in inbox. No system change yet.
- **Telemetry Generated:**

```
{
  "source": "email_gateway", "event": "message_delivered",
  "sender": "billing@northwind-billing.com", "sender_display": "Northwind
Billing",
  "recipient": "j.harper@northwind.local", "subject": "Overdue Invoice
#INV-44821",
  "attachments": ["Invoice_44821.xlsm"], "spf": "fail", "dkim": "none",
  "external_sender": true, "url_count": 0, "ts": "T+0m"
}
```

- **Alerts Generated:** *Low confidence* — "Inbound mail, SPF fail + macro attachment + lookalike domain" (correlation rule).
- **State Changes:** victim.inbox += phish_email; campaign state INITIATED.
- **Visual Representation:** Victim desktop mail client shows unread email with external-sender banner; Red dashboard shows "Lure delivered ✓."
- **Network Representation:** Inbound mail flow arrow from internet cloud → mail gateway → user mailbox.
- **Detection Opportunities:** Gateway anti-phish, SPF/DKIM fail, lookalike-domain detection, user report button. **Earliest possible kill-chain break.**

Stage 2 — User Execution (T1204.002)

- **Goal:** Convert delivery into code execution by inducing the user to enable macros.
- **Attacker Action (simulated):** Victim opens attachment; on **Enable Content**, the engine treats the document macro as "fired." Implemented as: victim decision → if "enable," spawn child process event under the Office app.
- **Victim Impact:** Document appears to load; brief loading cue; no obvious harm.
- **Telemetry Generated:**

```
{
  "source": "sysmon", "event_id": 1, "event": "process_create",
  "host": "WKSTN-FIN-07", "user": "corp\\j.harper",
  "parent_image": "C:\\Program Files\\Microsoft Office\\EXCEL.EXE",
  "image":
"C:\\Windows\\System32\\WindowsPowerShell\\v1.0\\powershell.exe",
  "command_line": "powershell -w hidden -ep bypass -enc
<BASE64_DISPLAY_ONLY>",
  "ts": "T+6m"
}
```

- **Alerts Generated:** *Medium confidence* — "Office application spawned PowerShell" (classic macro execution signature).
- **State Changes:** WKSTN-FIN-07.state = SUSPICIOUS; victim.action = enabled_macro.
- **Visual Representation:** Process-tree node EXCEL.EXE → powershell.exe lights up amber on SOC console.
- **Network Representation:** No external traffic yet (local only).

- **Detection Opportunities:** Office→script-interpreter parent/child rule; ASR rule "block Office child process creation"; user could still close without enabling (decision point).

Stage 3 — PowerShell Execution (T1059.001)

- **Goal:** Run a download cradle to fetch and launch the loader.
- **Attacker Action (simulated):** PowerShell "download cradle" reaches out to a **simulated** staging host and pulls `loader` into memory. No real download occurs — the engine fires a network event to a mock destination and transitions host state.
- **Victim Impact:** Faint disk/CPU activity; otherwise invisible.
- **Telemetry Generated:**

```
{
  "source": "powershell_operational", "event_id": 4104,
  "host": "WKSTN-FIN-07", "user": "corp\\j.harper",
  "script_block_text": "<obfuscated download cradle - display only>",
  "indicators": ["IEX", "DownloadString", "FromBase64String", "-
EncodedCommand"],
  "ts": "T+7m"
}
{ "source": "network", "event": "dns_query", "host": "WKSTN-FIN-07",
  "query": "cdn.update-svc-northwind[.]com", "ts": "T+7m" }
```

- **Alerts Generated:** *Medium-High* — "Suspicious PowerShell: encoded command + download cradle indicators (4104)."
- **State Changes:** `WKSTN-FIN-07.state = COMPROMISED; loader_present = true.`
- **Visual Representation:** Amber → orange host status; script-block snippet viewable in alert detail.
- **Network Representation:** Outbound DNS/HTTPS arrow from WKSTN-FIN-07 → staging host (newly registered domain).
- **Detection Opportunities:** Script block logging (4104), encoded-command detection, newly-registered-domain network rule, EDR memory-load heuristic. **Coverage toggle:** author can disable 4104 logging to teach the cost of telemetry gaps.

Stage 4 — Scheduled Task Creation (T1053.005)

- **Goal:** Persist across reboots.
- **Attacker Action (simulated):** Create scheduled task `\Microsoft\Windows\UpdateOrchestrator\NWUpdate` that relaunches the loader at logon. Implemented as a registry/task entity + event.
- **Victim Impact:** None visible.
- **Telemetry Generated:**

```
{ "source": "windows_security", "event_id": 4698, "event":
"scheduled_task_created",
  "host": "WKSTN-FIN-07", "user": "corp\\j.harper",
  "task_name": "\\Microsoft\\Windows\\UpdateOrchestrator\\NWUpdate",
  "action": "powershell.exe -w hidden ...", "trigger": "AtLogon", "ts":
"T+9m" }
```

- **Alerts Generated:** *Medium* — "New scheduled task with masquerading name running script interpreter."
- **State Changes:** WKSTN-FIN-07.persistence = scheduled_task; survives simulated reboot.
- **Visual Representation:** Persistence badge added to host node; "survives reboot" indicator.
- **Network Representation:** None.
- **Detection Opportunities:** 4698 task-creation monitoring, masquerading-name detection, baseline of normal scheduled tasks. Removing the task without removing other persistence leaves the host re-infectable (teachable).

Stage 5 — Process Injection (T1055.012) (*hollowing-class, simulated*)

- **Goal:** Run the beacon inside a trusted process to evade casual inspection.
- **Attacker Action (simulated):** Beacon code is represented as "injected" into a legitimate svchost.exe/explorer.exe context. Implemented purely as a telemetry + state marker; no real injection.
- **Victim Impact:** None visible.
- **Telemetry Generated:**

```
{ "source": "edr", "event": "suspicious_thread_injection",
  "host": "WKSTN-FIN-07", "source_image": "powershell.exe",
  "target_image": "C:\\Windows\\System32\\svchost.exe",
  "technique": "remote_thread_creation", "confidence": 0.72, "ts": "T+11m"
}
```

- **Alerts Generated:** *High* — "Cross-process injection into system binary (EDR behavioral)."
- **State Changes:** WKSTN-FIN-07.beacon_host_process = svchost.exe; killing PowerShell no longer kills the beacon (raises eradication difficulty).
- **Visual Representation:** Beacon icon now nested inside a trusted-process node; SOC process tree shows anomalous thread edge.
- **Network Representation:** Subsequent C2 appears to originate from svchost.exe, not PowerShell.
- **Detection Opportunities:** EDR behavioral injection detection, anomalous network from svchost, parent/owner mismatch. This is where EDR coverage clearly outperforms log-only SOC (teachable contrast).

Stage 6 — Command and Control (T1071.001)

- **Goal:** Establish reliable, interactive remote control over HTTPS.
- **Attacker Action (simulated):** Beacon checks in to C2 cdn.update-svc-northwind[.]com on a jittered interval, enabling operator hands-on-keyboard. Implemented as periodic synthetic network events on the clock.
- **Victim Impact:** None visible; minor periodic network traffic.
- **Telemetry Generated:**

```
{ "source": "network", "event": "https_beacon", "host": "WKSTN-FIN-07",
  "process": "svchost.exe", "dest": "cdn.update-svc-northwind[.]com",
  "dest_ip": "203.0.113.45", "bytes_out": 812, "bytes_in": 1440,
  "interval_s": 60, "jitter": 0.2, "ja3": "<hash>", "ts": "T+12m..." }
```

- **Alerts Generated:** *Medium-High* — "Periodic beaconing / low-variance interval to newly seen destination."
- **State Changes:** Campaign state `C2_ESTABLISHED`; Red role gains interactive session.
- **Visual Representation:** Pulsing link WKSTN-FIN-07 → internet C2 node; Red dashboard shows "Session live."
- **Network Representation:** Repeating outbound HTTPS arrows at regular intervals; bandwidth small but rhythmic.
- **Detection Opportunities:** Beacon-interval analytics, JA3/TLS fingerprinting, newly-registered-domain reputation, proxy egress logging. **Blocking the C2 destination here severs operator control — a high-value Blue action.**

Stage 7 — File Discovery (T1083)

- **Goal:** Understand the environment and locate valuable data and shares.
- **Attacker Action (simulated):** Operator enumerates local files, mounted drives, and network shares; queries AD for hosts and servers. Implemented as discovery events + population of a "reachable assets" list.
- **Victim Impact:** None visible.
- **Telemetry Generated:**

```
{ "source": "sysmon", "event_id": 1, "host": "WKSTN-FIN-07",
  "command_line": "cmd /c dir, net view, net share, nltest /domain_trusts
(display_only)",
  "ts": "T+18m" }
{ "source": "windows_security", "event_id": 5145, "event":
"network_share_access",
  "host": "FS01", "share": "\\FS01\\Finance", "user": "corp\\j.harper",
  "ts": "T+19m" }
```

- **Alerts Generated:** *Low-Medium* — "Recon command burst" + "Unusual share enumeration by Finance user."
- **State Changes:** `reachable_assets = [FS01, BKP01, DC01, 12 workstations]`; targets identified.
- **Visual Representation:** Asset graph expands; discovered nodes outlined; high-value targets flagged.
- **Network Representation:** Fan-out of SMB/LDAP probe arrows from WKSTN-FIN-07 to multiple internal hosts.
- **Detection Opportunities:** Recon-command detection, anomalous share access by role, AD enumeration alerts (e.g., honey-token share access). Discovery noise is a strong early-internal signal often missed.

Stage 8 — Lateral Movement via Remote Services / RDP (T1021.001 / T1563.002)

- **Goal:** Reach and control high-value servers.
- **Attacker Action (simulated):** Using harvested/valid credentials, the operator RDPs to FS01, BKP01, and eventually DC01. Implemented as logon events + new footholds in entity graph.
- **Victim Impact:** None on patient zero; target servers now compromised.
- **Telemetry Generated:**

```
{ "source": "windows_security", "event_id": 4624, "logon_type": 10,
  "event": "rdp_logon", "src_host": "WKSTN-FIN-07", "dest_host": "FS01",
  "account": "corp\\svc_backup", "ts": "T+27m" }
{ "source": "windows_security", "event_id": 4624, "logon_type": 10,
  "dest_host": "DC01", "account": "corp\\svc_backup", "ts": "T+33m" }
```

- **Alerts Generated:** *High* — "RDP from workstation to server using service account," "Service account interactive logon," "Lateral movement pattern (workstation → multiple servers)."
- **State Changes:** FS01.state = COMPROMISED, BKP01.state = COMPROMISED, DC01.state = COMPROMISED; spread radius grows.
- **Visual Representation:** New compromised (red) nodes; lateral-movement edges animate from patient zero outward.
- **Network Representation:** RDP (3389) connections workstation → servers; east-west traffic spike.
- **Detection Opportunities:** Logon-type-10 anomalies, service-account interactive logon, workstation→server RDP, impossible/abnormal access patterns. **Disabling the abused account or isolating servers here is the last clean save before impact.**

Stage 9 — Data Encrypted for Impact (T1486)

- **Goal:** Encrypt data across reachable systems to force payment.
- **Attacker Action (simulated):** Encryptor is "staged" to compromised hosts and detonated. **Implementation: a sandboxed renamer over a synthetic file set** — files get a `.locked` suffix, a placeholder marker replaces content in the simulated filesystem, and a ransom note is dropped. No cryptography, no real files touched outside the simulation sandbox.
- **Victim Impact:** Files become inaccessible (`.locked`); wallpaper changes; `README_RESTORE.txt` opens.
- **Telemetry Generated:**

```
{ "source": "edr", "event": "mass_file_modification",
  "host": "FS01", "process": "nw_enc.exe (simulated)",
  "files_modified": 18452, "rate_per_min": 6100,
  "extensions_added": [".locked"], "note_file": "README_RESTORE.txt",
  "ts": "T+41m" }
{ "source": "file_audit", "event_id": 4663, "host": "FS01",
  "action": "write/rename burst", "ts": "T+41m" }
```

- **Alerts Generated:** *Critical* — "Mass file rename/modification (ransomware behavior)," "Canary/honeyfile modified," "Ransom-note file pattern detected."
- **State Changes:** Affected hosts → ENCRYPTED; `business_operations` = HALTED; impact meter spikes.
- **Visual Representation:** Hosts flash to black/red "locked"; file icons convert to `.locked`; victim desktop shows ransom note overlay.
- **Network Representation:** Encryption may be local; if network shares targeted, SMB write bursts to FS01 shares appear.
- **Detection Opportunities:** Honeyfile/canary triggers, mass-modification rate threshold, ransom-note signature, automated EDR rollback (if enabled). Detection here is *late* — high impact already incurred. Scoring reflects this.

Stage 10 — Inhibit System Recovery (T1490)

- **Goal:** Prevent restoration to force ransom payment.
- **Attacker Action (simulated):** Delete volume shadow copies, disable recovery, and tamper with backup catalogs on BKP01. Implemented as state flags + events; the "Restore from backup" Blue action becomes unavailable once these fire.
- **Victim Impact:** Even IT cannot quickly restore; outage extends.
- **Telemetry Generated:**

```
{ "source": "sysmon", "event_id": 1, "host": "FS01",
  "command_line": "vssadmin delete shadows /all /quiet ; wbadmin delete
catalog (display only)",
  "ts": "T+44m" }
{ "source": "edr", "event": "backup_service_tamper", "host": "BKP01",
  "detail": "backup catalog deleted / service stopped", "ts": "T+45m" }
```

- **Alerts Generated:** *Critical* — "Shadow copy deletion," "Backup service tampering."
- **State Changes:** `recovery_available = false`; `backups_intact = false`; `max business-impact path locked in`.
- **Visual Representation:** Backup node turns red; "Restore" button greys out on Blue dashboard with "Backups compromised" tooltip.
- **Network Representation:** Access to BKP01 (often via prior RDP foothold).
- **Detection Opportunities:** `vssadmin/wbadmin` command detection, backup-service-stop monitoring, immutable/offline backups (a *preventive* control the scenario can reward if pre-configured). Catching shadow-deletion commands is a well-known high-fidelity ransomware tell.

8. Propagation Logic

Spread is modeled as graph traversal over the entity graph, gated by reachability and credentials.

- **Reachability:** Host B is reachable from compromised host A if a network link exists *and* the relevant port/service is allowed by segmentation (User VLAN → Server VLAN: RDP allowed, User VLAN → Backup VLAN: blocked by default *unless* mis-segmented or via DC).
- **Credential gating:** Lateral movement to a host requires a credential valid on that host. The simulation maintains a `credentials` pool harvested over time; each lateral hop consumes a valid credential edge.
- **Propagation function (per tick after C2):**
 1. Pick highest-value reachable, not-yet-compromised host with an available credential.
 2. Roll against current **heat** and any active Blue containment (isolation/account-disable can block the hop).
 3. On success → mark host `COMPROMISED`, harvest any local credentials, expand reachable set.
- **Encryption spread:** Only `COMPROMISED` hosts can be encrypted. Encryption is a separate, later phase so defenders have a window between footholds and impact.
- **Segmentation as a control:** If the author pre-configures proper segmentation (Backup VLAN unreachable from User VLAN, no flat DC trust), BKP01 may be unreachable, making T1490 fail and preserving recovery — directly rewarding good architecture.

9. Business Impact Logic

A running **business-impact score** (and dollar estimate, for narrative) accumulates based on what's compromised, encrypted, and recoverable.

Factor	Contribution
Patient zero compromised	Low (single user downtime)
File server (FS01) encrypted	High (shared data, many users blocked)
Domain controller (DC01) compromised	High (authentication / domain trust)
Backups inhibited (T1490)	Multiplier — converts a recoverable incident into a potential-payment / extended-outage incident
Time-to-containment	Cost accrues per simulated hour of operations halted
Data classes encrypted	Finance/PII weighted higher (regulatory exposure)

Formula sketch (for engineering):

```
impact =  $\Sigma$ (asset_weight × encrypted?)  
        + downtime_hours × hourly_ops_cost  
        + (backups_inhibited ? recovery_penalty : 0)  
        + (regulated_data_encrypted ? compliance_penalty : 0)  
        - early_containment_credit
```

The defender's final score is inversely related to `impact` and directly related to *how early* the chain was broken.

10. Defender Decision Points

These are the explicit fork nodes where SOC/Blue choices change the trajectory. Each is a scorable event.

#	Trigger	Options	Best outcome
DP-1	Phish delivered (Stage 1)	Report / quarantine mail / ignore	Mail quarantined org-wide before open
DP-2	Office→PowerShell alert (Stage 2–3)	Investigate+isolate / dismiss	Isolate WKSTN-FIN-07 pre-C2
DP-3	Beaconing detected (Stage 6)	Block C2 / monitor / dismiss	Sever C2, then eradicate
DP-4	Recon/share enum (Stage 7)	Scope + isolate / wait	Contain before lateral movement
DP-5	RDP lateral movement (Stage 8)	Disable account + isolate servers / wait	Stop spread before impact

#	Trigger	Options	Best outcome
DP-6	Mass-modification alert (Stage 9)	Mass-isolate + invoke IR / triage slowly	Limit encryption blast radius
DP-7	Shadow/backup tamper (Stage 9–10)	Protect/disconnect backups / too late	Preserve recovery if reached in time

Proportionality scoring: over-reaction (e.g., disabling 200 accounts on DP-2) incurs a business-friction penalty; correct, scoped action earns full credit. This discourages "isolate everything" reflexes.

11. Success Conditions

Defined per role so the engine can score independently.

Defender (SOC + Blue) success tiers:

- **Platinum:** Chain broken at DP-1 or DP-2 (before C2). No encryption, minimal friction.
- **Gold:** C2 severed (DP-3) and host eradicated before lateral movement.
- **Silver:** Contained during/after lateral movement (DP-4/DP-5) before any encryption.
- **Bronze:** Encryption limited to patient zero or a single host; backups preserved; fast recovery.

Victim success: reported phish at inbox stage, or refused Enable Content, or promptly reported impact.

Red Team "success" (for the attacker role / scoring the offensive player): reaching `MISSION_COMPLETE` (Stage 10) before containment, low total heat, fast time-to-impact.

12. Failure Conditions

Defender failure (max-impact path):

- Campaign reaches `ENCRYPTED` on FS01/DC01 **and** `recovery_available = false` (T1490 fired).
- Critical alerts (injection, beaconing, shadow deletion) dismissed as false positives.
- Containment applied to the wrong host/account while spread continues.

Partial failure: encryption occurs but backups preserved (recoverable) — costly but survivable.

Victim failure: enabled content **and** failed to report at any stage.

Engine guardrails: the simulation cannot proceed past a stage if its prerequisite state isn't set (e.g., no encryption without prior compromise), preventing illogical jumps and keeping replays consistent.

13. State Machine

Campaign-level states (global):

INITIATED → DELIVERED → EXECUTED → PERSISTED → C2_ESTABLISHED
 → DISCOVERY → LATERAL_MOVEMENT → ENCRYPTING → RECOVERY_INHIBITED →
 MISSION_COMPLETE

└─ (any Blue containment that breaks prerequisites) —→ CONTAINED → ERADICATED → RECOVERED

Per-host states:

CLEAN → SUSPICIOUS → COMPROMISED → (BEACONING) → ENCRYPTED

└─ ISOLATED / REMEDIATED ┘

Transition rules (selected):

From	Event	To	Guard
CLEAN	macro_enabled	SUSPICIOUS	victim chose Enable Content
SUSPICIOUS	ps_cradle_fired	COMPROMISED	PowerShell execution event
COMPROMISED	beacon_checkin	BEACONING	C2 reachable (not blocked)
BEACONING	C2_blocked (Blue)	COMPROMISED	egress block active → operator loses session
COMPROMISED	isolate (Blue)	ISOLATED	host quarantined; spread from it stops
COMPROMISED	encryptor_detonate	ENCRYPTED	host still controlled; not isolated
any	full_remediation	CLEAN	persistence + beacon + creds all cleared

Key guard: isolating a host stops spread *from* it but does not clean it; full remediation requires clearing **persistence (Stage 4) + beacon (Stage 5) + harvested creds (Stage 8)**. Partial cleanup → re-infection (teachable mechanic).

14. Simulation Timeline

Default scripted timeline (simulated clock; compress to real-time playthrough as needed). Times are illustrative anchors for event scheduling.

Sim time	Stage	Event	Earliest defender break
T+0m	1	Phish delivered	DP-1
T+6m	2	Macro enabled → PowerShell	DP-2
T+7m	3	Download cradle + first DNS	DP-2
T+9m	4	Scheduled task created	—
T+11m	5	Process injection	DP-2

Sim time	Stage	Event	Earliest defender break
T+12m	6	C2 beaconing begins	DP-3
T+18m	7	File/host discovery	DP-4
T+27m	8	RDP to FS01	DP-5
T+33m	8	RDP to DC01	DP-5
T+41m	9	Mass encryption begins	DP-6
T+44m	10	Shadow copy deletion	DP-7
T+45m	10	Backup tamper → MISSION_COMPLETE	(too late)

Pacing control: each interval is configurable. "Easy" mode stretches the gap between C2 (T+12m) and encryption (T+41m) to give defenders more reaction time; "Hard" mode compresses it and disables some telemetry (e.g., 4104).

15. End-to-End Scenario Blueprint

A consolidated implementation reference tying the pieces together.

Environment (entity graph seed):

- Domain: corp.northwind.local
- Segments: User VLAN, Server VLAN, Backup VLAN, DMZ
- Hosts: WKSTN-FIN-07 (patient zero, user j.harper), 40 workstations, DC01, FS01, BKP01, mail gateway, proxy/egress
- Accounts: j.harper (Finance), svc_backup (over-privileged service acct — the lateral-movement enabler), domain admins
- High-value targets: FS01, DC01, BKP01
- Authored variables (toggles): script-block-logging on/off, EDR injection-detection on/off, segmentation strict/flat, backups immutable/online, pacing easy/hard

Component map for engineering:

Component	Responsibility
Clock/scheduler	Advances ticks; fires scripted stage events or awaits role decisions
Entity graph	Hosts, accounts, files, links, states; source of truth for reachability
Event bus / telemetry generator	Emits synthetic logs per stage to SIEM/EDR feeds
Detection engine	Runs simulated rules over events → produces Alert objects with confidence
Role services	Red, Victim, SOC, Blue dashboards subscribe to relevant events/state
Scoring engine	Listens to decisions + state; computes per-role scores and business impact

Component	Responsibility
Visualization layer	Asset map, process trees, network flows, victim desktop, ransom overlay

Data contracts (suggested):

- `Event { id, source, type, host, user, fields{}, ts, stage }`
- `Alert { id, rule, severity, confidence, related_event_ids[], stage }`
- `Decision { role, action, target, ts }`
- `EntityState { entity_id, type, state, flags{persistence, beacon_process, creds[]} }`

Recommended build order:

1. Entity graph + clock + state machine (Sections 13–14).
2. Telemetry generator emitting Stage 1–10 events (Section 7).
3. SOC view consuming events + detection engine producing alerts.
4. Blue action panel mutating state (Section 6) + propagation logic (Section 8).
5. Victim desktop + Red dashboard.
6. Scoring + business-impact + decision points (Sections 9–12).
7. Author toggles + difficulty pacing.

Role-as-first-class-entity note (for a GoalCert-style platform): each role here has its own *view contract* (which events/state it can see), *action set* (what it can do), and *scoring rubric* (Sections 11–12). This keeps roles as independent, swappable drivers — and leaves a clean seam to later replace a human Red or SOC role with an automated/agentic driver that consumes the same event bus and emits the same `Decision` objects.

Appendix A — MITRE ATT&CK Mapping (reference index)

Stage	Technique	ID
1	Spear Phishing (Attachment / Link)	T1566.001 / T1566.002
2	User Execution (Malicious File)	T1204.002
3	Command & Scripting: PowerShell	T1059.001
4	Scheduled Task/Job	T1053.005
5	Process Injection (Hollowing-class)	T1055.012
6	Application Layer Protocol (Web)	T1071.001
7	File and Directory Discovery	T1083
8	Remote Services (RDP) / Remote Service Session Hijack	T1021.001 / T1563.002
9	Data Encrypted for Impact	T1486
10	Inhibit System Recovery	T1490

All techniques are referenced for detection/storyboarding purposes only. No procedure-level offensive content, exploit code, or malware is included or required for implementation.